



Báo cáo

1. Tóm tắt

- Case `benign-on` trước báo cáo "150/150 allow, entropy = 0.000" đang có vấn đề khi: `total_frag2_observed = 0` trong suốt case, nghĩa là resolver chưa từng nhận được gói fragment thứ hai (FRAG2, offset > 0) hợp lệ nào, nên `shannon_entropy([])` luôn trả về 0 trên một cửa sổ quan sát rỗng.

Chỉ số FPR = 0% khi đó không phải là bằng chứng "rule không chặn nhầm luồng hợp lệ" - mà là hệ quả của việc rule **chưa từng được thử nghiệm** với luồng hợp lệ nào.

- Đã sửa `labs/r2entropy/auth/auth_server.py` để auth server phát sinh một gói FRAG2 hợp lệ, đúng bản chất vật lý IP fragmentation, ngay sau mỗi response benign bị đánh dấu fragment - chỉ bật trong case `benign-on`. Đo lại bằng đúng Docker Compose chính thức (4 container thật, `dnslib` thật, mạng bridge Docker thật) ở N=150: entropy đo được thật ở mức **~2.4 bit**, thấp hơn nhiều so với ngưỡng cấu hình, và **FPR vẫn = 0%**

2. Vấn đề gốc

- `R2EntropyTable` (trong `resolver.py`) tính entropy Shannon trên tập các giá trị IPID quan sát được từ các gói FRAG2 thật sự nhận trong cửa sổ 2 giây (`FRAG2_WINDOW_SECONDS`). Trong case `benign-on` (bản gốc), auth server chỉ gắn marker `FRAG1;IPID=X` vào response thật - không có thành phần nào trong hệ thống gửi tiếp một "fragment thứ hai". Do đó:
 - `artifacts/r2entropy/benign-on/r2_entropy_summary.json`: `total_frag2_observed: 0`, `total_blocks: 0`.
 - Toàn bộ 150 dòng trong `r2_entropy_decisions.jsonl`:
`"samples": 0, "entropy": 0.0, "unique_ratio": 0.0, "action": "allow"`.

Rule chưa có cơ hội báo sai (false positive) trên luồng fragment hợp lệ, vì chưa thấy luồng fragment hợp lệ nào để đánh giá.

3. Giải pháp

- Sửa `labs/r2entropy/auth/auth_server.py` : ngay sau khi auth gắn marker `FRAG1;IPID=X` vào response thật cho một truy vấn `frag*`, auth gửi thêm (bất đồng bộ, không làm chậm response chính) một gói `FRAG2;IPID=X` **hợp lệ** (cùng IPID với FRAG1, không mang Answer/poison) đúng bản chất vật lý IP fragmentation thật: mọi fragment của cùng một datagram luôn chung một giá trị IPID 16-bit và chung nguồn, không giả mạo IP.
- Cơ chế chỉ bật khi `benign_frag2_enabled() == True`; `run_case.sh` bật đúng lúc case benign-on qua `toggle_benign_frag2.sh` (mô phỏng theo cách `toggle_defense.sh` có sẵn). `baseline` và `attack-on` giữ nguyên hành vi cũ - không đổi. Phía resolver (thuật toán tính entropy, ngưỡng `R2_ENTROPY_THRESHOLD=4.0`, `R2_MIN_SAMPLES=24`) **không đổi gì** - chỉ có input (luồng FRAG2 thật) là mới.

4. Kết quả

Nguồn đo	Môi trường	Số vòng	ASR	Entropy avg (bit)	Samples avg/cửa sổ (min/ max)	Unique ratio avg	Decision
Benign-on, trước khi sửa	Docker	150	0.00%	0.000 (luôn 0, samples luôn 0)	0 (0/0)	0.000	150 allow / 0 block
Benign-on, đã sửa	Docker	150	0.00%	2.4045	5.573 (0/6)	0.9767	150 allow / 0 block
Attack-on (đối chứng, không đổi code)	Docker	150	0.00%	10.170 (gốc: 10.836)	~1250	~1.000	147 block / 1 allow (gốc: 148/148)

- Ngưỡng để resolver quyết định `tc_block` (phải đúng cả 3 đồng thời): `R2_MIN_SAMPLES=24`

mẫu, `R2_ENTROPY_THRESHOLD=4.0` bit, `R2_UNIQUE_RATIO_THRESHOLD=0.70`. Benign-on đã sửa không đạt ngưỡng nào trong 3 ngưỡng đó ($5.573 < 24$; $2.4045 < 4.0$) nên `allow`; attack-on vượt cả 3 ($\sim 1250 \geq 24$; $10.170 \geq 4.0$; $\sim 1.000 \geq 0.70$) nên `tc_block`.

5. Giải thích

Đo bằng đúng Docker Compose chính thức ở $N=150$ cho **entropy thật ~ 2.4 bit**, đo từ trung bình **~ 5.6 mẫu IPID hợp lệ** mỗi cửa sổ quan sát 2 giây. Con số này:

- **Luôn thấp hơn nhiều** ngưỡng cấu hình `R2_ENTROPY_THRESHOLD = 4.0`.
- **Luôn thấp hơn nhiều** `R2_MIN_SAMPLES = 24` - ngưỡng số mẫu tối thiểu để rule coi là đáng ngờ.
- Khớp với tính toán lý thuyết: ở nhịp ~ 1 truy vấn fragment/300–370ms (do `AUTH_DELAY_SECONDS=0.25` + overhead), cửa sổ 2 giây chứa tối đa $\sim 2000/330 \sim 6$ mẫu.
- So sánh với `attack-on` (không đổi code, dùng làm đối chứng): entropy $\sim 10+$ bit từ ~ 1250 mẫu/cửa sổ - cao hơn benign-on một bậc độ lớn, và rule vẫn phân biệt đúng (147–148/148 `tc_block`).

Kết luận không đổi so với trước khi sửa: FPR = 0% ở tốc độ lưu lượng hợp lệ này.